ENERMAN · REPORTE DE AUDITORÍA DE SOFTWARE

Cumplimiento de Projectra frente a normas ISO y OWASP

Revisión del sistema de gestión de proyectos de ENERMAN (ampr.site): qué ya cumple, qué cumple a medias, qué falta y en qué orden conviene atenderlo.

Fecha de corte **9 oct 2026** Base **auditoría del 29 sep 2026, re-verificada hoy**

Tipo **evaluación interna de ENERMAN** Método **revisión de código + pruebas en vivo de solo lectura**

Versión del código **commit cc4793b**

RESUMEN

18 controles evaluados

5	10	2	1
Cumple	Cumple parcial	No cumple	Sin evaluar

Las bases de seguridad son sólidas: no se encontró inyección SQL ni XSS, las contraseñas se guardan cifradas, los archivos subidos se validan y no pueden ejecutarse, y las acciones quedan registradas en una bitácora. La mayoría de los "parciales" se resuelven con ajustes de configuración pequeños. Hay dos "no cumple": la API confía en cualquier sitio de vercel.app (H14) y un archivo de diagnóstico expuesto (H1).

Atender primero: H14 · la API confía en cualquier sitio de vercel.app

La configuración CORS acepta con sesión cualquier origen `https://*.vercel.app`. Cualquiera puede publicar gratis una página ahí; si un usuario con sesión abierta en Projectra la visita, esa página puede leer los datos del sistema a nombre del usuario. Verificado en producción el 9 oct 2026. Se corrige dejando solo los dominios propios en la lista permitida.

También urgente: H1 · diag.php público en producción

`https://ampr.site/api/diag.php` responde sin iniciar sesión con el nombre de la base de datos y el número de registros de cada tabla. No expone contraseñas ni datos personales, pero un auditor lo marcaría como exposición de información. Se corrige borrando el archivo del servidor.

ALCANCE

Qué se evaluó y con qué criterio

El reporte tiene tres capas:

- **Checklist técnico de 18 controles**: OWASP Top 10 (2021), la referencia práctica de ISO/IEC 27034 y OWASP ASVS, y las ocho características de ISO/IEC 25010. Se califican con evidencia del código.
- **Evaluación norma por norma** de las 14 normas ISO propuestas: grado de preparación del sistema y de la empresa, qué evidencia ya existe y qué falta.
- **Cómo se audita** cada tipo de norma y la ruta sugerida.

Las normas certificables (27001, 27701, 20000-1, 22301, 9001) evalúan sobre todo **procesos y documentos de la empresa**. El sistema aporta evidencia para ellas, pero no basta por sí solo para certificarlas.

METODOLOGÍA

Cómo se evaluó y con qué criterios se calificó

Evaluación interna de cumplimiento aplicada por ENERMAN a su sistema Projectra, con revisión de código asistida por herramientas de análisis. Es una autoevaluación técnica, no una auditoría de un organismo certificador: sirve para conocer el estado real del sistema y preparar una auditoría formal.

Qué se aplicó

TÉCNICA	QUÉ SE HIZO	QUÉ EVIDENCIA PRODUCE
Revisión estática de código	Lectura del código fuente completo del frontend (React/TypeScript) y de la API (PHP): autenticación, control de acceso, consultas a base de datos, subida de archivos, respaldos y configuración del servidor.	Archivo y línea donde se cumple o falla cada control.
Pruebas de solo lectura al sitio en vivo	Consultas HTTP a ampr.site para comprobar encabezados de seguridad y archivos expuestos. No se modificó ningún dato ni se hicieron ataques activos.	Respuesta real del servidor (código HTTP y contenido).
Análisis de dependencias	`npm audit` sobre las librerías de producción y de desarrollo, contra la base pública de vulnerabilidades de GitHub.	Conteo de vulnerabilidades por severidad.
Revisión documental	Procedimientos MAN-ADM-001 y MAN-ADM-004, documentación técnica del repositorio y flujos de publicación.	Correspondencia entre proceso documentado y sistema.
Pruebas funcionales locales	Para cada corrección: verificación de sintaxis y prueba del comportamiento en un servidor local antes de publicar.	Resultado esperado contra resultado obtenido.

Referencias usadas para calificar

REFERENCIA	EDICIÓN	PARA QUÉ SE USÓ
OWASP Top 10	`2021`	Los diez controles de seguridad del checklist 1.
OWASP ASVS	`4.0.3`	Detalle técnico de cada control (sesiones, archivos, encabezados).
OWASP Risk Rating Methodology	`vigente`	Criterio de severidad de los hallazgos (probabilidad × impacto).

REFERENCIA	EDICIÓN	PARA QUÉ SE USÓ
ISO/IEC 25010	2011	Las ocho características del checklist 2. La edición 2023 agrega una novena (protección/safety) y renombra algunas; se usó la de 2011 por ser la más adoptada.
ISO/IEC 25040	2011	Estructura del proceso de evaluación: requisitos, especificación, diseño, ejecución y conclusión.
ISO/IEC 27001 y 27002	2022	Requisitos del SGSI y numeración de controles (5 organizacionales, 6 personas, 7 físicos, 8 tecnológicos).
ISO/IEC 40500	2012	Equivalente a WCAG 2.0, criterio de accesibilidad.
Resto de normas ISO listadas	vigentes	Requisitos generales de cada norma para medir el grado de preparación.
LFPDPPP	vigente	Obligaciones legales en México sobre datos personales (aviso de privacidad).

Escala de calificación de controles

ESTADO	CRITERIO PARA ASIGNARLO
CUMPLE	El control está implementado, se verificó con evidencia de código o prueba, y no se encontró ninguna brecha.
PARCIAL	El control existe y funciona, pero hay al menos una brecha documentada como hallazgo.
NO CUMPLE	El control falta, o hay una falla verificada que alguien sin credenciales puede aprovechar.
SIN EVALUAR	Calificarlo requiere pruebas que aún no se realizan (usuarios, accesibilidad, carga). No se asume ni cumple ni falla.

Escala de preparación por norma

ESTADO	CRITERIO PARA ASIGNARLO
PARCIAL	Existe evidencia real para buena parte de los requisitos; faltan piezas concretas e identificadas.
INICIAL	Hay controles técnicos sueltos, pero falta el sistema de gestión documentado que exige la norma (políticas, riesgos, auditoría interna).
SIN EVALUAR	La norma se mide con pruebas que aún no se realizan.

Severidad de los hallazgos

NIVEL	CRITERIO (PROBABILIDAD × IMPACTO, OWASP RISK RATING)
ALTA	Aprovechable sin iniciar sesión y expone información interna o permite una acción no autorizada.
MEDIA	Requiere condiciones previas (usuario con sesión, acceso a la red), o afecta la continuidad del servicio o una obligación legal.
BAJA	Defensa adicional: el riesgo práctico es bajo porque otros controles ya lo cubren.
INFO / MEJORA	No es una vulnerabilidad; es consistencia, mantenimiento o madurez.

Regla de evidencia: ningún control se marcó como "Cumple" sin evidencia verificable, y ningún hallazgo se da por resuelto hasta que la corrección está publicada y se volvió a probar en el sitio en vivo.

APTITUDES DEL SISTEMA

Lo que Projectra ya hace

Flujo de proyectos por fases

Proceso de cuatro fases que sigue los procedimientos MAN-ADM-001 y MAN-ADM-004, con validación de campos obligatorios antes de guardar la Fase 1.

Control de acceso por rol

Cuatro perfiles (gestor, supervisor, administración, ingeniero). Cada acción del servidor verifica sesión y rol antes de ejecutarse.

Folio único por proyecto
Numeración secuencial con restricción de unicidad en la base de datos; el folio aparece en toda referencia a un proyecto.

Papelera con recuperación
Lo que se borra se archiva completo antes de eliminarse, con quién lo borró, y puede consultarse después.

Documentos con validación
Comprobantes, cotizaciones y reportes con tipo de archivo verificado por contenido real, límite de tamaño (30–45 MB) y nombre aleatorio en el servidor.

Comunicación por proyecto
Chat dentro de cada proyecto, con historial ligado al folio.

Publicación controlada
Ambiente de pruebas (staging) separado de producción y compilación con verificación estricta de tipos antes de cada publicación.

Bitácora de actividad
Registra quién hizo qué, cuándo, sobre qué entidad, con IP y navegador. Hoy contiene cerca de 68 mil registros.

Respaldos
Respaldo automático programado, protegido con clave, y script de respaldo manual de la base de datos.

Avisos y resumen diario
Notificaciones en el sistema según el rol, aviso por correo de aprobación y resumen diario con alertas de proyectos incompletos.

Consulta y exportación
Búsqueda y filtros operativos, administrativos y financieros, con exportación a CSV.

Sesiones protegidas
Contraseñas con bcrypt, bloqueo temporal tras intentos fallidos de acceso y cookies de sesión HttpOnly + Secure.

CHECKLIST 1 DE 2

OWASP Top 10 (2021)

ID	CONTROL	ESTADO	EVIDENCIA Y OBSERVACIÓN
A01	**Control de acceso**	NO CUMPLE	Las acciones de la API exigen sesión y rol (`requireAuth`, `requireAdmin`, `requireSystemAdmin`). Falla en dos puntos: la política CORS permite leer con la sesión del usuario desde cualquier sitio `*.vercel.app` (H14), y `diag.php` queda fuera del control (H1). api/core/auth_guards.php · api/routes/*.php

ID	CONTROL	ESTADO	EVIDENCIA Y OBSERVACIÓN
A02	**Fallas criptográficas**	PARCIAL	HTTPS activo, contraseñas con bcrypt, cookies Secure. Falta forzar HTTPS con HSTS (H5) y la publicación usa FTP sin cifrar, que manda la contraseña del servidor en claro (H4). api/core/functions.php · .github/workflows/deploy.yml
A03	**Inyección (SQL, XSS)**	CUMPLE	Todas las consultas usan sentencias preparadas (PDO). El frontend no inserta HTML sin escapar y los correos escapan con `htmlspecialchars`. 0 usos de dangerouslySetInnerHTML en src/
A04	**Diseño inseguro**	PARCIAL	La subida de archivos no verifica de qué sitio viene la petición; otro sitio podría hacer que el navegador de un usuario con sesión suba un archivo a sus propios proyectos (CSRF, H2). api/routes/uploads.php
A05	**Configuración de seguridad**	NO CUMPLE	Archivo de diagnóstico público en producción (H1). Falta política de contenido (CSP) y la carpeta de la API no tiene su propio archivo de encabezados de seguridad (H5, H8). Sí hay X-Frame-Options, nosniff y Referrer-Policy. Probado contra ampr.site el 7 oct 2026
A06	**Componentes vulnerables**	PARCIAL	Las dependencias que se publican: **0 vulnerabilidades**. Las herramientas de desarrollo (Vite, Tailwind, PostCSS): 14 avisos (10 altos) que no llegan al servidor, pero un auditor los vería al correr `npm audit` (H9). npm audit --omit=dev → 0 · npm audit → 14

ID	CONTROL	ESTADO	EVIDENCIA Y OBSERVACIÓN
A07	**Identificación y autenticación**	PARCIAL	Hay bloqueo por intentos fallidos y contraseñas cifradas. Faltan: renovar el identificador de sesión al iniciar sesión (H3), retirar la contraseña por defecto escrita en el código y el soporte heredado de contraseñas en texto plano (H6). No hay segundo factor. api/routes/auth.php · api/core/functions.php:342
A08	**Integridad de software y datos**	PARCIAL	Publicación automatizada desde el repositorio con compilación verificada. El canal de subida (FTP sin cifrar) no garantiza la integridad en tránsito (H4). .github/workflows/deploy.yml
A09	**Registro y monitoreo**	CUMPLE	Bitácora con usuario, rol, acción, entidad, IP y navegador, incluido cada inicio de sesión. Mejora sugerida: alertas automáticas ante patrones anómalos. tabla activity_logs · logActivity()
A10	**Falsificación de peticiones del lado servidor (SSRF)**	CUMPLE	El servidor no descarga direcciones que proporcione el usuario, así que no existe esta superficie de ataque.

CHECKLIST 2 DE 2

ISO/IEC 25010 · Calidad del producto

CARACTERÍSTICA	ESTADO	EVIDENCIA Y OBSERVACIÓN
Adecuación funcional	CUMPLE	Cubre el ciclo completo de solicitud → proyecto → facturación → pago descrito en MAN-ADM-001 y MAN-ADM-004, con validación de campos obligatorios por fase.
Eficiencia de desempeño	PARCIAL	Funciona con el volumen actual, pero las notificaciones se consultan cada 4 segundos sobre una tabla que crece sin límite, y la bitácora ya ronda 68 mil registros sin política de depuración (H10). Sin pruebas de carga.

CARACTERÍSTICA	ESTADO	EVIDENCIA Y OBSERVACIÓN
Compatibilidad	PARCIAL	Aplicación web estándar; intercambia datos por CSV y correo. Falta una prueba formal en varios navegadores y en móvil.
Usabilidad	SIN EVALUAR	No se ha medido formalmente. Para medirla: Lighthouse y axe-core (accesibilidad WCAG) más recorridos automatizados por rol con Playwright, que ya está instalado en el proyecto (H11).
Fiabilidad	PARCIAL	Respaldos, papelera recuperable y operaciones atómicas por campo para evitar que un usuario sobrescriba el trabajo de otro. Faltan pruebas automatizadas y monitoreo de disponibilidad.
Seguridad	PARCIAL	Ver checklist OWASP: 3 cumple, 5 parcial, 2 no cumple.
Mantenibilidad	PARCIAL	TypeScript estricto, documentación de campos y bitácora de migraciones. No hay pruebas automatizadas que protejan contra regresiones. docs/CAMPOS.md · docs/MIGRATION_LOG.md
Portabilidad	CUMPLE	Tecnologías estándar (React, PHP, MySQL) en hosting convencional, con ambiente de pruebas separado. Se puede mover de proveedor sin reescribir.

OPORTUNIDADES DE MEJORA

Hallazgos agrupados por prioridad

H14

ALTA **CORS acepta cualquier sitio de vercel.app con sesión**

`api/index.php` responde con `Access-Control-Allow-Origin` y `Allow-Credentials: true` a todo origen que cumpla `https://*.vercel.app`, y la cookie de sesión es `SameSite=None`. Una página de terceros en vercel.app puede leer las respuestas de la API con la sesión de quien la visite. No se detectó en la revisión del 29 de septiembre ni en la del 7 de octubre; lo encontró la revisión hecha desde la segunda laptop el 9 de octubre.

Corrección: quitar el comodín de vercel.app y dejar solo los dominios propios (y, si se usa Vercel, el dominio exacto del proyecto). Revisar también si la cookie puede volver a `SameSite=Lax`. Esfuerzo: menos de una hora.

H1

ALTA **Archivo de diagnóstico expuesto**

`api/diag.php` está publicado y responde sin sesión con el nombre de la base y el conteo de cada tabla. El script de publicación lo excluye, así que se subió por otra vía.

Corrección: borrarlo del servidor y confirmar que devuelve 404. Esfuerzo: minutos.

H2

MEDIA **Subida de archivos sin protección CSRF**

El resto de la API está protegida porque usa JSON; la subida usa formulario multipart, que el navegador no bloquea desde otros sitios.

Corrección: validar el encabezado `Origin` contra la lista de dominios permitidos en esa acción. Esfuerzo: menos de una hora.

H3

MEDIA **La sesión no se renueva al iniciar sesión**

Sin `session_regenerate_id` después del login, un identificador de sesión plantado antes del acceso sigue siendo válido después (fijación de sesión).

Corrección: una línea en el inicio de sesión normal y en el de gestor. Esfuerzo: minutos.

H4

MEDIA **Publicación por FTP sin cifrar**

La publicación automática y la de staging usan `protocol: ftp`; usuario, contraseña y archivos viajan sin cifrar.

Corrección: cambiar a FTPS o SFTP (Hostinger soporta ambos) y rotar la contraseña FTP. Esfuerzo: una hora.

H12

MEDIA **Respaldos en el mismo servidor e incompletos**

El respaldo diario (30 días de retención) se guarda en el mismo hosting que la base de datos: si se pierde el servidor, se pierden ambos. Incluye usuarios, proyectos, solicitudes y notificaciones, pero no los archivos subidos, el chat, la bitácora ni la configuración. El script manual `database/backup.ps1` apunta a una base de datos con otro nombre.

Corrección: copia diaria fuera del servidor (otro proveedor o almacenamiento en la nube), incluir todas las tablas y la carpeta de archivos, corregir el script y hacer una prueba de restauración documentada. Esfuerzo: uno a dos días.

H13

MEDIA **Sin aviso de privacidad**

El sistema guarda nombres, correos, IP y navegador de sus usuarios, además de datos de clientes, y no muestra aviso de privacidad. En México lo exige la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), aunque no se busque certificación.

Corrección: redactar el aviso (idealmente con asesoría legal), mostrarlo en el inicio de sesión y definir cuánto tiempo se conservan la bitácora y las IP.

H5

BAJA **Faltan CSP y HSTS**

La única política de contenido presente es la que agrega Hostinger (`upgrade-insecure-requests`). No hay `Strict-Transport-Security`.

Corrección: agregar ambos encabezados al `.htaccess` y probar que la app siga cargando. Esfuerzo: una o dos horas.

H6

BAJA **Contraseña por defecto en el código**

La contraseña inicial está escrita en el código para usuarios semilla y restauraciones, y el login todavía acepta contraseñas guardadas en texto plano (las convierte a bcrypt al primer acceso).

Corrección: confirmar que ninguna cuenta conserva una contraseña en texto plano, retirar ese soporte y obligar a cambiar la contraseña inicial. Esfuerzo: medio día.

H7

BAJA **Clave del respaldo automático**

Se compara con `!==` en lugar de `hash_equals()` y viaja en la URL, donde queda en los registros del servidor.

Corrección: comparación en tiempo constante y una clave más larga y aleatoria. Esfuerzo: minutos.

H8

INFO **API sin encabezados de seguridad propios**

Los encabezados de seguridad solo cubren el frontend. La API responde JSON, por eso el impacto es bajo, pero la configuración queda inconsistente.

Corrección: agregar un `.htaccess` en `api/` con los mismos encabezados.

H9

INFO **Herramientas de desarrollo desactualizadas**

14 avisos en Vite, Tailwind y PostCSS. No afectan producción, pero aparecen en cualquier revisión con `npm audit`.

Corrección: actualizar las dependencias. Subir de versión mayor a Tailwind 4 y Vite 8 requiere pruebas, así que conviene planearlo aparte.

H10

MEJORA **Crecimiento de notificaciones y bitácora**

Las dos tablas crecen sin límite y las notificaciones se consultan completas cada 4 segundos. Ya está identificado como parte del rediseño de notificaciones.

Corrección: política de retención (por ejemplo, archivar después de 12 meses) y consultas incrementales.

H11 MEJORA **Pruebas automatizadas y auditoría de usabilidad**

Playwright está instalado pero no hay pruebas escritas. Sin ellas, la usabilidad queda sin medir y cada cambio depende de pruebas manuales.

Corrección: reporte de auditorías (local, prueba, staging, producción) con revisión de accesibilidad, axe-core y Lighthouse.

AVANCE DE MEJORAS

Correcciones en curso

Estado al cierre de la revisión. Las calificaciones del checklist reflejan el sistema **publicado**; una corrección cambia la calificación solo después de publicarse y volver a verificarse en vivo.

HALLAZGO	ESTADO	QUÉ SE HIZO
H14 · CORS vercel.app	CORRECCIÓN LISTA, SIN SUBIR	Corregido en la segunda laptop (commit local `f8c9fff`), pendiente de subir a una rama y probar en staging.
H1 · diag.php público	LISTO, SIN PUBLICAR	Se encontró la causa: el script de publicación manual decía excluir el archivo pero no lo hacía. Se corrigió el script y se agregó una regla del servidor que bloquea `diag.php` y `config.php` aunque estén presentes. Falta borrar el archivo del servidor.
H2 · CSRF en subida	LISTO, SIN PUBLICAR	La API rechaza envíos de sitios no autorizados. Probado localmente: origen ajeno → 403; ampr.site y sin origen → sin cambios. Mientras H14 siga abierto, cualquier sitio de vercel.app cuenta como autorizado.
H3 · Fijación de sesión	LISTO, SIN PUBLICAR	El identificador de sesión se renueva en cada inicio de sesión, normal y de gestor.
H4 · FTP sin cifrar	EN PRUEBA	El ambiente de pruebas (staging) ya publica por FTPS. Producción se cambia cuando staging confirme que funciona con Hostinger.

HALLAZGO	ESTADO	QUÉ SE HIZO
H5 · HSTS y CSP	HSTS LISTO, SIN PUBLICAR	HSTS agregado al frontend y a la API. CSP queda pendiente porque requiere probar que la aplicación siga cargando todos sus recursos.
H7 · Clave del respaldo	LISTO, SIN PUBLICAR	Comparación en tiempo constante (`hash_equals`). Falta cambiar la clave por una más larga en el servidor.
H8 · Encabezados de la API	LISTO, SIN PUBLICAR	Nuevo archivo de configuración en `api/` con los mismos encabezados de seguridad que el frontend.
H6, H9 a H13	PENDIENTE	Planeados según la ruta sugerida.

EVALUACIÓN NORMA POR NORMA

Preparación frente a las 14 normas ISO

Parcial: hay evidencia real y faltan piezas concretas. **Inicial**: existen controles sueltos, pero falta el sistema de gestión que pide la norma. **Sin evaluar**: requiere pruebas que aún no se hacen.

Certificables (auditoría formal)

NORMA	ESTADO	LO QUE YA HAY	LO QUE FALTA
ISO/IEC 27001 Seguridad de la información (SGSI)	INICIAL	Controles técnicos: acceso por rol, contraseñas cifradas, bitácora, respaldos, validación de archivos.	El SGSI documentado: alcance, política de seguridad, análisis de riesgos, Declaración de Aplicabilidad, gestión de altas y bajas de accesos, auditoría interna y revisión por la dirección. Además, corregir H1 a H7.

NORMA	ESTADO	LO QUE YA HAY	LO QUE FALTA
ISO/IEC 27701 Privacidad y datos personales	INICIAL	Acceso a datos restringido por rol; contraseñas nunca visibles.	Aviso de privacidad (H13), inventario de datos personales, procedimiento para derechos ARCO y plazos de conservación. Requiere tener primero la 27001.
ISO/IEC 20000-1 Gestión del servicio de TI	INICIAL	Ambiente de pruebas, publicación automatizada e historial de cambios en git.	Catálogo de servicios, niveles de servicio acordados, registro de incidentes y solicitudes de soporte, monitoreo de disponibilidad y quién aprueba cada cambio.
ISO 22301 Continuidad del negocio	PARCIAL	Respaldo diario automático, función de restauración y papelera recuperable.	Respaldo fuera del servidor y completo (H12), tiempos objetivo de recuperación (RTO/RPO), análisis de impacto y prueba de restauración documentada.
ISO 9001 Gestión de la calidad	PARCIAL	El sistema implementa los procedimientos MAN-ADM-001 y MAN-ADM-004, guarda registros con trazabilidad por folio y genera indicadores diarios.	Sistema de gestión de calidad de la empresa: objetivos e indicadores formales, acciones correctivas, medición de satisfacción del cliente y auditoría interna. Projectra puede ser la herramienta que lo sostenga.

De evaluación técnica (criterio, no certificado)

NORMA	ESTADO	EVALUACIÓN
ISO/IEC 25010 / 25040 Calidad del producto	PARCIAL	Ver checklist: 2 cumple, 5 parcial, 1 sin evaluar. Este reporte es una primera evaluación; la 25040 pide además fijar métricas y umbrales de aceptación antes de medir.

NORMA	ESTADO	EVALUACIÓN
ISO/IEC 27002 Catálogo de controles	PARCIAL	Controles tecnológicos: cumple registro de actividad (8.15) y gestión de accesos privilegiados (8.2). Parciales: autenticación segura (8.5), respaldo (8.13), criptografía (8.24) y desarrollo seguro (8.25 a 8.28). Falla gestión de la configuración (8.9) por H1. Los controles organizacionales, de personas y físicos no se evaluaron.
ISO/IEC 27034 Seguridad en aplicaciones	PARCIAL	Evaluada con OWASP Top 10: 3 cumple, 5 parcial, 2 no cumple. Falta formalizar requisitos de seguridad por aplicación.
ISO/IEC 27017 / 27018 Nube y datos personales en la nube	INICIAL	El sistema vive en hosting de Hostinger. Falta revisar su contrato y política de tratamiento de datos, la ubicación de los servidores y qué responsabilidades son del proveedor y cuáles de ENERMAN.
ISO/IEC/IEEE 12207 Ciclo de vida del software	PARCIAL	Control de versiones, staging, compilación verificada y documentación de campos y migraciones. Faltan requisitos formales, revisión de código registrada y criterios de liberación.
ISO/IEC/IEEE 29119 Pruebas de software	INICIAL	No hay plan de pruebas ni pruebas automatizadas; hoy se prueba a mano. Es la brecha técnica más grande (H11).
ISO/IEC 40500 Accesibilidad web (WCAG 2.0)	SIN EVALUAR	El idioma de la página está declarado y hay algunas etiquetas de accesibilidad, pero falta medirlo con axe-core y revisión manual de teclado y contraste.
ISO 9241 Usabilidad y ergonomía	SIN EVALUAR	Requiere pruebas con usuarios reales de cada rol: eficacia, eficiencia y satisfacción (9241-11).
ISO/IEC 38500 Gobierno de TI	INICIAL	Norma para la dirección: quién decide sobre TI y cómo se priorizan inversiones y riesgos. Falta definirlo por escrito.

CÓMO SE AUDITA

Proceso de auditoría y ruta sugerida

Normas certificables

Las audita un organismo certificador acreditado (en México, ante la ema). Etapa 1: revisión de documentos. Etapa 2: auditoría en sitio, donde se pide evidencia de que lo documentado se cumple. El certificado dura tres años, con auditorías de seguimiento anuales.

Normas técnicas

No dan certificado. Se evalúan contra el criterio de la norma, de forma interna o con un tercero, y se entregan como reporte con evidencia: pruebas de seguridad, mediciones de accesibilidad, pruebas de usabilidad y revisión de código.

- **Días:** corregir H14, H1 a H4 y H7. Cierra los dos "no cumple" y la mayoría de los parciales de OWASP.
- **Semanas:** respaldos externos y completos (H12), aviso de privacidad (H13), CSP y HSTS (H5) y contraseñas iniciales (H6).
- **Uno a dos meses:** pruebas automatizadas por rol con revisión de accesibilidad (H11), política de retención de datos (H10) y actualización de dependencias (H9).
- **Si el cliente exige certificación:** la base es ISO/IEC 27001 y la 27701 se construye encima. Requiere un proyecto de documentación de la empresa, no solo del sistema.

LÍMITES DE ESTA REVISIÓN

Lo que no se verificó

- Usabilidad y accesibilidad con usuarios o herramientas automatizadas.
- Rendimiento bajo carga y tiempos de respuesta medidos.
- Configuración interna del hosting (versiones de PHP y MySQL, permisos del servidor).
- Pruebas de penetración activas contra el sitio en vivo. Solo se hicieron consultas de lectura.

Reporte elaborado sobre el código fuente del repositorio de Projectra (commit cc4793b) y consultas de solo lectura a ampr.site el 7 de octubre de 2026. Los estados reflejan esa fecha; cada hallazgo corregido debe volver a verificarse antes de presentarse como resuelto.